

Security Incident Response Policy

Policy ID

POL-SEC-007

Effective Date

20 March 2026

Owner

Security Operations

Purpose

This policy defines the organization's approach to identifying, containing, investigating, and recovering from security incidents.

Incident Examples

Incidents may include credential compromise, malware, unauthorized access, data leakage, phishing, exposed secrets, suspicious infrastructure activity, or compromise of an AI or retrieval system.

Reporting

Employees and systems should report suspected incidents through approved security channels. Reports should include the observed behavior, affected system, approximate time, and available evidence when known.

Triage

Security personnel assess severity, scope, affected assets, and potential business impact. Incidents may be categorized according to the organization's severity model and escalated to appropriate stakeholders.

Containment

Depending on the incident, responders may disable accounts, revoke tokens, isolate hosts, block network paths, quarantine documents, or restrict access to affected services.

Evidence

Relevant logs, alerts, system metadata, and other evidence should be preserved where appropriate. Personnel should avoid altering evidence unnecessarily during investigation.

Recovery

Systems may be restored after containment and validation. Credentials or keys suspected of compromise must be rotated or revoked. Post-incident monitoring may be increased.

Lessons Learned

Significant incidents should result in a documented review identifying root causes, control gaps, corrective actions, and owners. AI-related incidents should include an assessment of prompts, retrieved context, model behavior, and tool permissions where relevant.